CARLOS GABRIEL GOMES LUZ

APPLICATION SECURITY (APPSEC) | DEVSECOPS | SOFTWARE ENGINEERING

São Paulo, SP | +55 (11) 96762-2665 | carlosgabriel.contato2007@gmail.com
linkedin.com/in/dev-carlosgabriel | github.com/CarlossgLuz | carlosg.com.br

PROFESSIONAL SUMMARY

Junior Systems Development Analyst with hands-on experience in application security (AppSec), ASPM, and DevSecOps, currently pursuing specialization in the field. Involvement in XGuardian's evolution, contributing to vulnerability management, software supply chain security, access control, and automation initiatives. Solid background in development and operations, enabling the connection of security requirements to code, integrations, and the application lifecycle. A workflow integrating generative AI, decision-making models, agents, and APIs/MCP integrations to support technical investigations, quality assurance (QA) testing, and process improvement.

PROFESSIONAL EXPERIENCE

Xmart Solutions | Santo André, SP, Brazil

Junior Systems Development Analyst | Jun/2026 – Present

- Contributed to the evolution of XGuardian, a SaaS AppSec and ASPM platform, enhancing features and SAST, SCA, DAST, Container Security, and SBOM reports to improve the visualization and contextualization of security findings.
- Developed and enhanced dashboards, metrics, filters, and vulnerability analysis workflows, including scan quota controls by application and team, with an emphasis on data consistency and operational usability.
- Investigated and contextualized vulnerabilities and dependencies using references such as OWASP Top 10, NIST NVD, MITRE CVE/CWE, CVSS, and the GitHub Advisory Database, also considering component end-of-life (EOL).
- Participated with the team in assessing and developing role-based access control (RBAC), covering roles, permissions, access segregation, and protection of platform operations and APIs.
- Provided technical assistance and support for the Sonatype ecosystem, documentation, and enterprise environment troubleshooting, including a financial-sector deployment intended for hundreds of developers. Also participated in vendor technical meetings conducted in English. Xmart Solutions is currently a Brazilian Sonatype partner with multiple professionals trained and qualified in implementing and supporting its ecosystem.
- Participated in the technical partnership between Xygeni and Xmart Solutions, with platform access, specialist-led training, and evaluation of AppSec and software supply chain security capabilities.
- Used Semgrep, OWASP ZAP, Gitleaks, and Dependabot in studies and validations.
- Applied generative AI workflows and automation to engineering and security activities, integrating models, agents, and tools via APIs and MCP to support technical analysis, documentation, QA, and controlled workflow execution, with attention to permissions and data protection, managing overall agent governance and auditing decisions.

Systems Development Intern | Dec/2025 – Jun/2026

- Worked in technical support, Linux and Proxmox environments, observability with Zabbix and Grafana, and web development, along with responsibilities involving networks and infrastructure. Progressively expanded responsibilities until promotion to the junior analyst position.

EDUCATION

UNICID | Technology Degree in Systems Analysis and Development | Jun/2026 – Dec/2027 (expected)

SENAI | Technical Diploma in Systems Development | Jul/2024 – Jun/2026

PROZ | Technical Diploma in Internet Computing | Jan/2023 – Dec/2024

SELECTED PROJECTS & INITIATIVES

Automated QA (Quality Assurance) System for Platform Validation

Developed an internal solution to support pre- and post-release platform testing, including validation of features, integrations, and permissions, with customizable controlled executions, evidence recording, and traceability. An initiative aimed at reducing reliance on exclusively manual checks, saving time and personnel for validation.

SAST Tool Benchmarking

Created and evolved controlled scenarios based on recognized references such as the OWASP Benchmark to assess coverage, accuracy, and the occurrence of false positives and false negatives, supporting comparative tool analysis and technical validation of security results.

Orchestration and Auditing of AI Agents and Skills

Explored and developed workflows using commercial and open models, agents, APIs, and the Model Context Protocol (MCP) to automate technical routines. Emphasis on governance, traceability, access control, and responsible model use.

Open-Vaultin | AI Agent Harness Governance | open source

Independent, continuously improving open-source project (Early V1) focused on Harness Engineering and AI agent governance. Provides agents and skills, policies, Codex lifecycle hooks, durable context, execution ledger and evidence, Git/MCP knowledge synchronization, and advisory task routing with the JEV/TypeSafe decision model and deterministic fallback. The host retains the main agent loop; enforcement depends on client integration. github.com/CarlossgLuz/Open-Vaultin

APIsec | independent API security laboratory

Public FastAPI lab demonstrating BOLA, BFLA, and BOPLA (OWASP API Security Top 10:2023). Compares vulnerable and protected behavior in isolated synthetic-data scenarios, with Pytest, Ruff, Bandit, Docker, GitHub Actions CI, and Markdown/JSON evidence reports. Does not scan third-party systems. github.com/CarlossgLuz/APIsec-LabTest

TECHNICAL SKILLS

AppSec & DevSecOps: CI/CD, ASPM, SAST, SCA, DAST, Container Security, Secrets Scanning, SBOM, Secure SDLC, Secure Code Review, Vulnerability Management, EOL, Supply Chain Security, and RBAC.

Vulnerability Analysis: OWASP Top 10, NIST NVD, MITRE CVE/CWE, CVSS, GitHub Advisory Database.

Tools & Integrations: XGuardian, Sonatype Guide, Nexus Repository, Nexus Lifecycle/IQ, Nexus Firewall, Xygeni, Semgrep, OWASP ZAP, Gitleaks, Dependabot, GitHub Actions, and GitLab CI/CD.

AI & Automation: Commercial and open-source LLMs, Hugging Face, agents, APIs, MCP, model routing, prompt engineering, workflow orchestration, and governance.

Development & Operations: Python, JavaScript, TypeScript, React, Next.js, REST APIs, SQL, Git/GitHub, Linux, Docker, AWS, Azure, Proxmox, Zabbix, Grafana, and Prometheus.

CERTIFICATIONS & LANGUAGES

Microsoft Azure Fundamentals (AZ-900) | Feb/2026

Scrum Foundation Professional Certification (SFPC) | Oct/2024 – Oct/2027

English: B2 (Upper-Intermediate) | Used in documentation and international technical meetings; currently improving through private lessons.